Tarea 3 · Módulo 3: Reconocimiento Pasivo y Activo Básico

Alumna: Angélica María Quezada Bautista

Parte 1 – Reconocimiento Pasivo con Google Dorks

Cada alumno debe:

1. Crear 8 búsquedas diferentes usando:

Dork usado:

Site:

¿Qué encontró?:

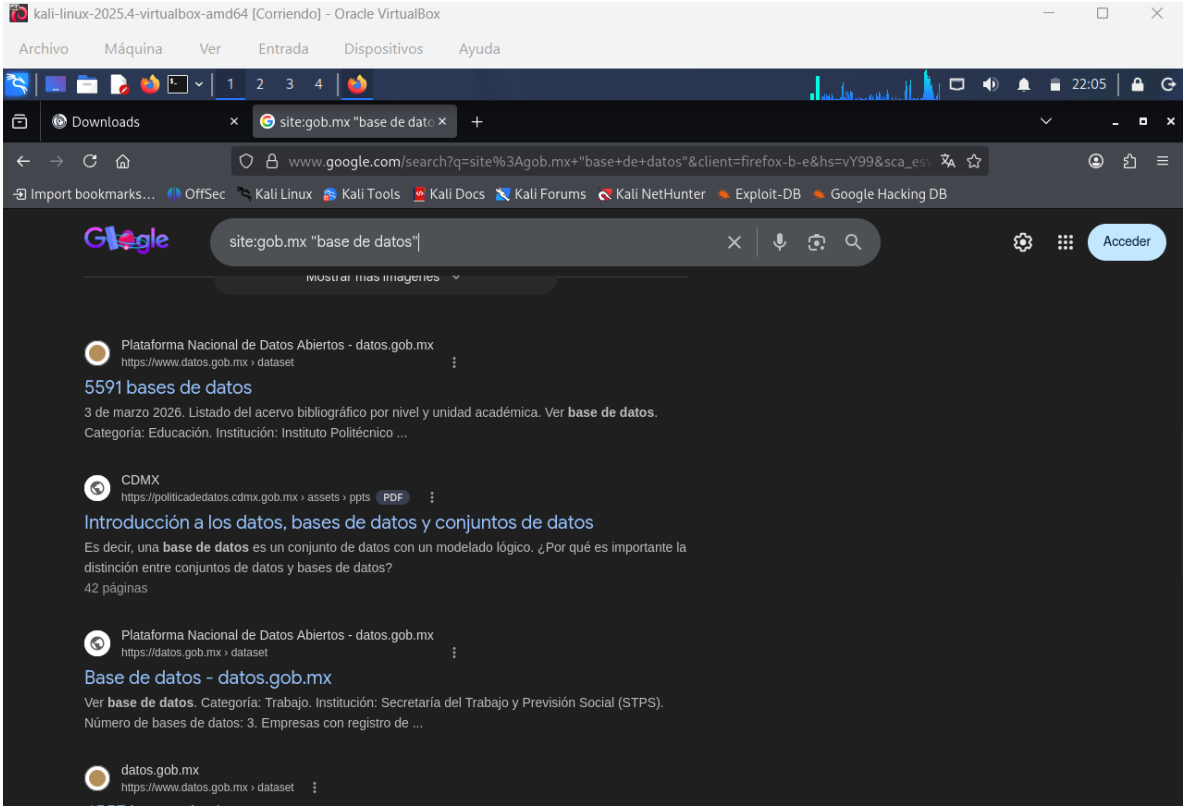
Documentos que mencionen bases de datos en sitios del gobierno.

Documentos PDF y páginas informativas.

¿Representa un riesgo o no?

Bajo, Solo información pública, no contiene datos sensibles

Captura de pantalla



Filetype:

¿Qué encontró?:

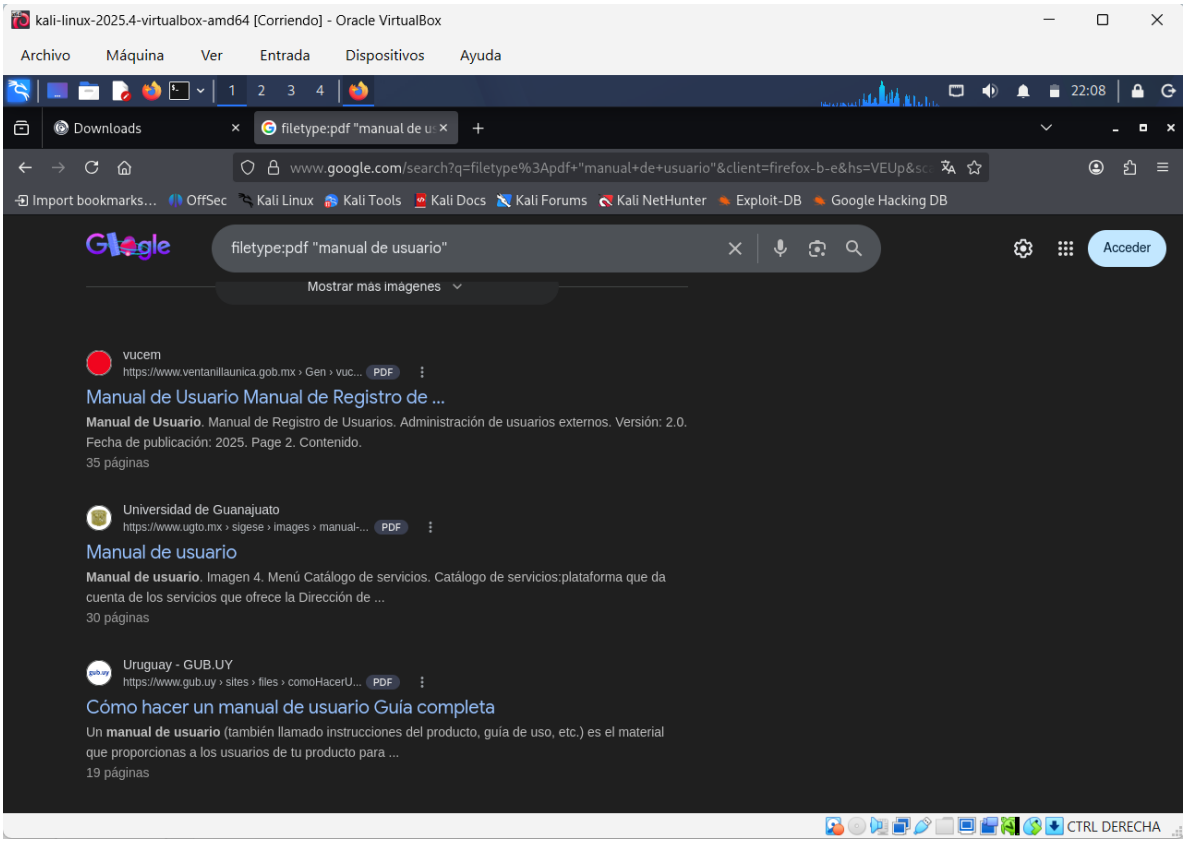
Manuales en formato PDF

Manuales técnicos de diferentes instituciones.

¿Representa un riesgo o no?

Bajo, son documentos públicos.

Captura de pantalla:



Inurl:

¿Qué encontró?:

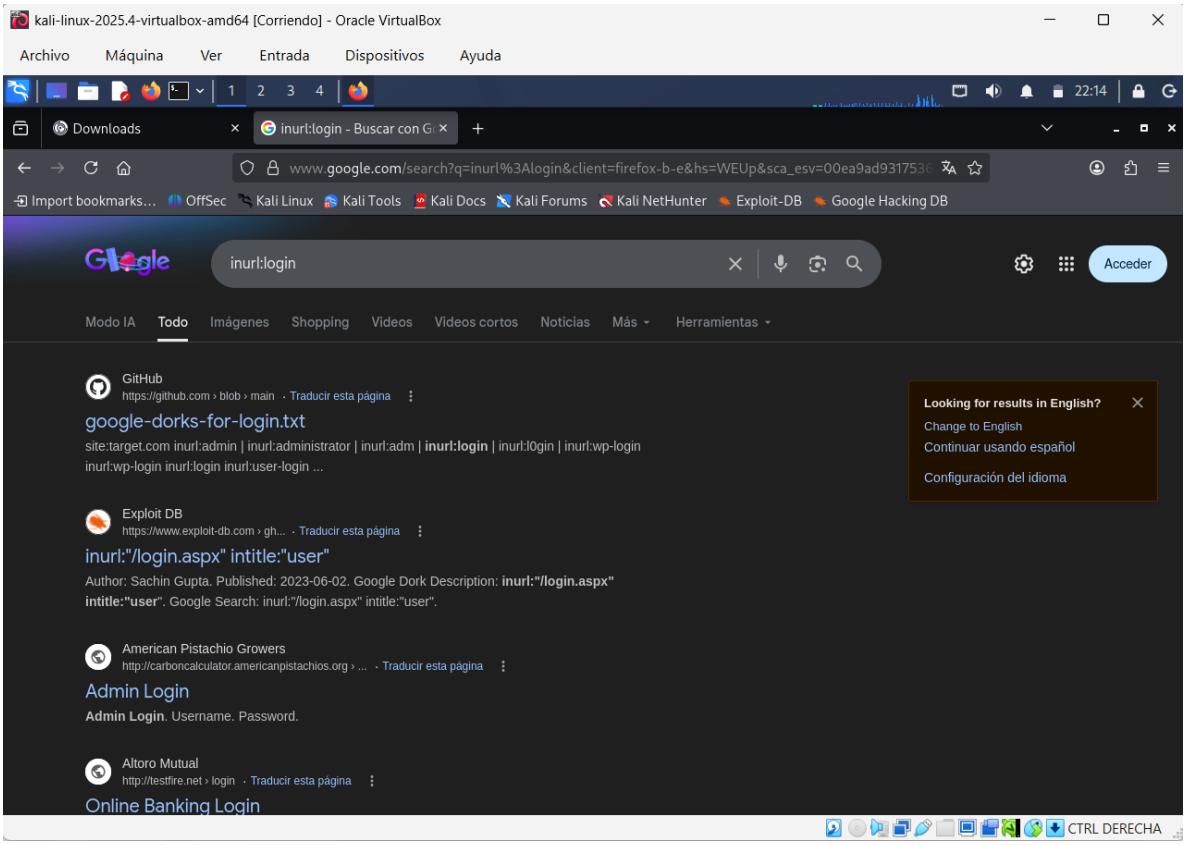
Páginas que contienen login en la URL

Páginas de acceso a sistemas

¿Representa un riesgo o no?

Medio, podrían ser puntos de acceso a sistemas.

Captura de pantalla:



Intitle:

¿Qué encontró?:

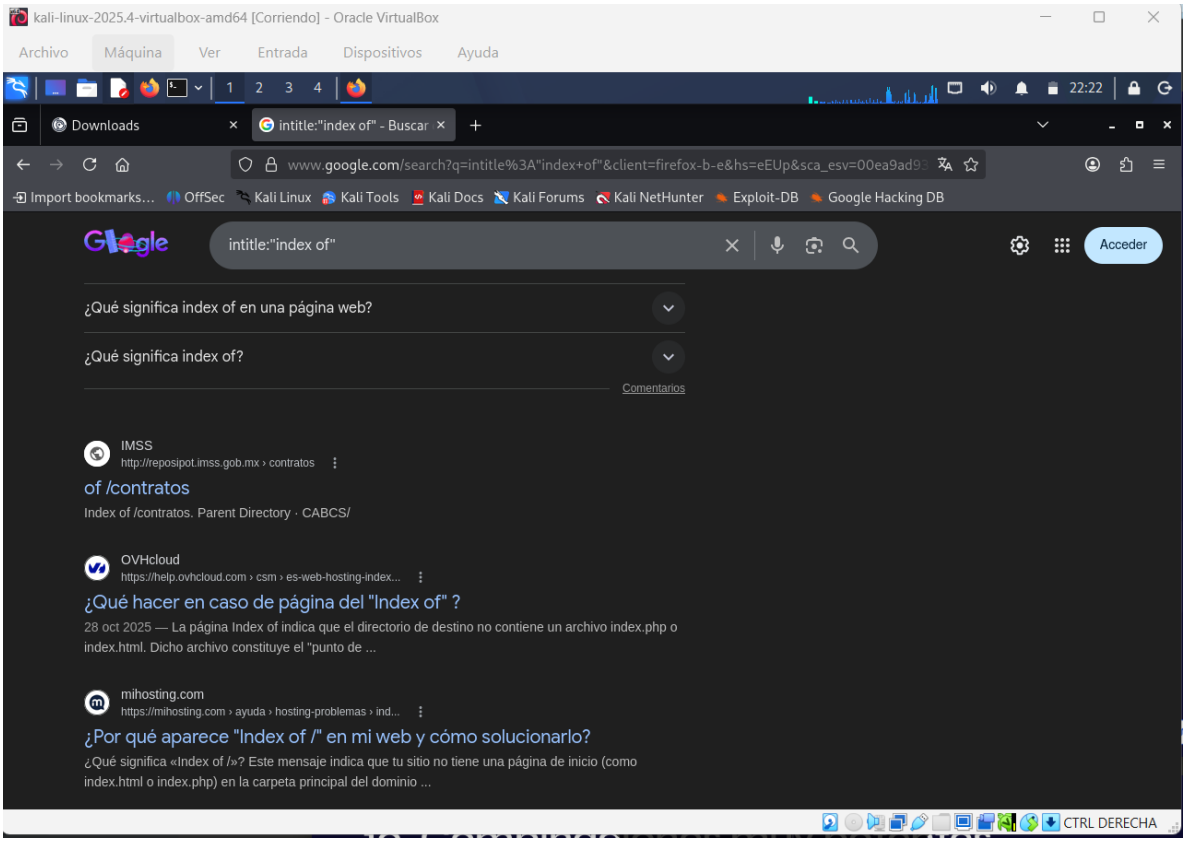
Directorios abiertos en servidores.

Listas de archivos accesibles

¿Representa un riesgo o no?

Alto, puede exponer archivos internos

Captura de pantalla:



site:edu.mx filetype:xls

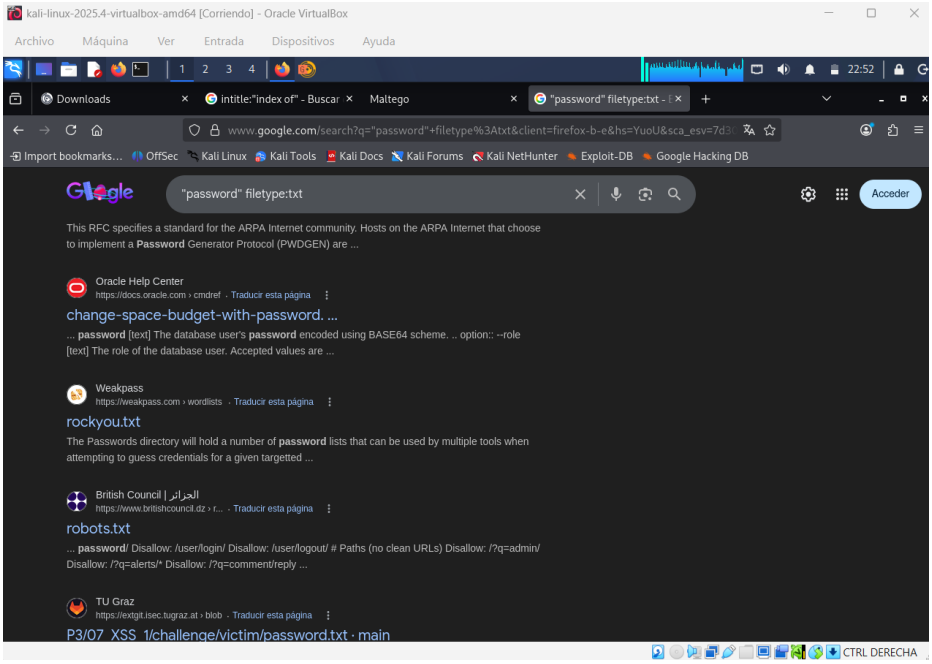
¿Qué encontró?:

Archivos Excel con listados de información académica.

¿Representa un riesgo o no?

Medio, porque algunos archivos pueden contener datos internos.

Captura de pantalla:



site:gob.mx -pdf

¿Qué encontró?:

Resultados de sitios del gobierno excluyendo PDF

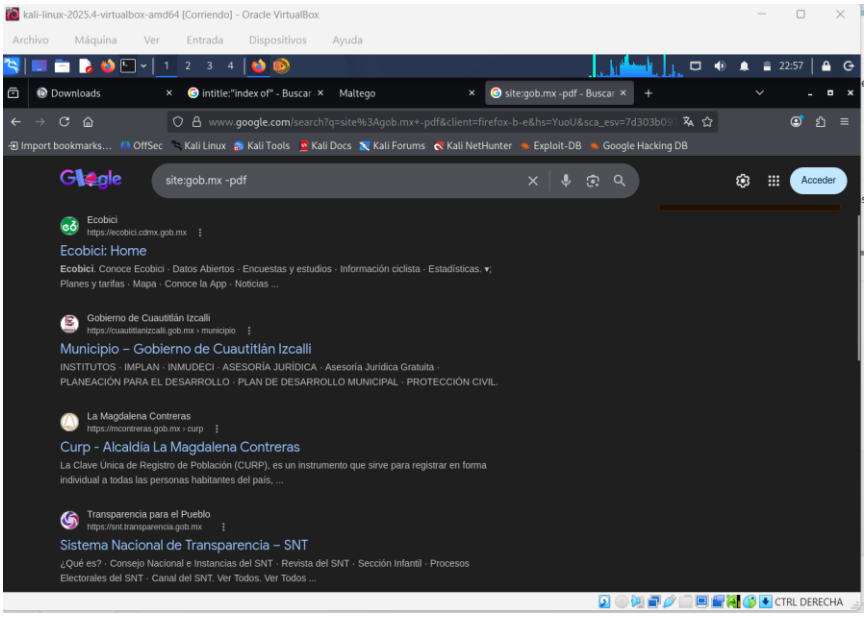
Páginas web informativas

¿Representa un

riesgo o no?

Bajo, solo contenido informativo.

Captura de pantalla:



Parte 2 – Investigación en GHDB

Entrar a Exploit Database y:

1. Buscar 3 dorks

Dork 1

Dork:

intitle:"index of" "backup"

Qué busca:
Busca directorios abiertos en servidores web que contengan archivos de respaldo o backup.

Qué tipo de exposición detecta:

- **Archivos de respaldo de sitios web**
- **Copias de bases de datos**
- **Archivos comprimidos (.zip, .tar, .bak)**

Categoría en GHDB:
Files Containing Juicy Info

Riesgo:
Alto, porque los archivos de respaldo pueden contener código del sitio, configuraciones o datos sensibles.

Dork 2

Dork:

inurl:admin login

Qué busca:
Localiza páginas web que tengan la palabra admin en la URL y que estén relacionadas con un sistema de inicio de sesión.

Qué tipo de exposición detecta:

- Paneles de administración
- Acceso a sistemas internos
- Interfaces de gestión de sitios web

Categoría en GHDB:
Login Portals

Riesgo:
Medio, porque identifica puntos de acceso a sistemas administrativos que podrían ser objetivo de ataques si no están protegidos.

Dork 3

Dork:

filetype:sql "dump"

Qué busca:
Busca archivos con extensión .sql que contengan volcados de bases de datos.

Qué tipo de exposición detecta:

- Bases de datos expuestas
- Información de usuarios
- Tablas con datos almacenados

Categoría en GHDB:
Sensitive Online Shopping Info / Database Dumps

Riesgo:
Muy alto, porque puede revelar información confidencial almacenada en bases de datos.

Parte 3 – Maltego (Mapa Visual)

El objetivo de esta actividad es visualizar cómo se relacionan los elementos de una infraestructura en Internet utilizando la herramienta Maltego, que se usa en OSINT (Open Source Intelligence) y análisis de seguridad.

Paso 1. Crear un grafo nuevo

1. **Abrir Maltego.**
2. **En el menú seleccionar:**

New → New Graph

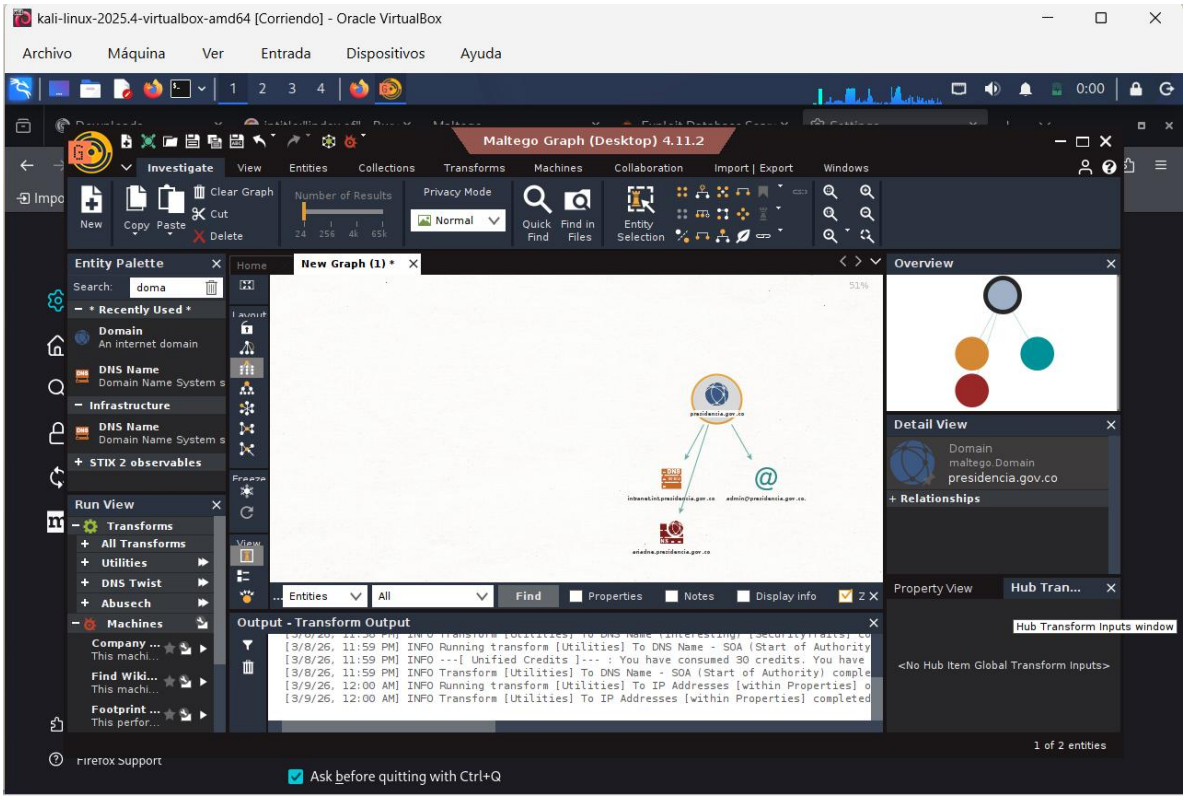
3. **Se abrirá un espacio vacío donde se construirán las relaciones.**

Paso 2. Agregar un dominio

1. **En el panel izquierdo buscar la entidad Domain.**
2. **Arrastrarla al área del grafo.**
3. **En el nombre escribir un dominio autorizado o de prueba, por ejemplo:**

example.com

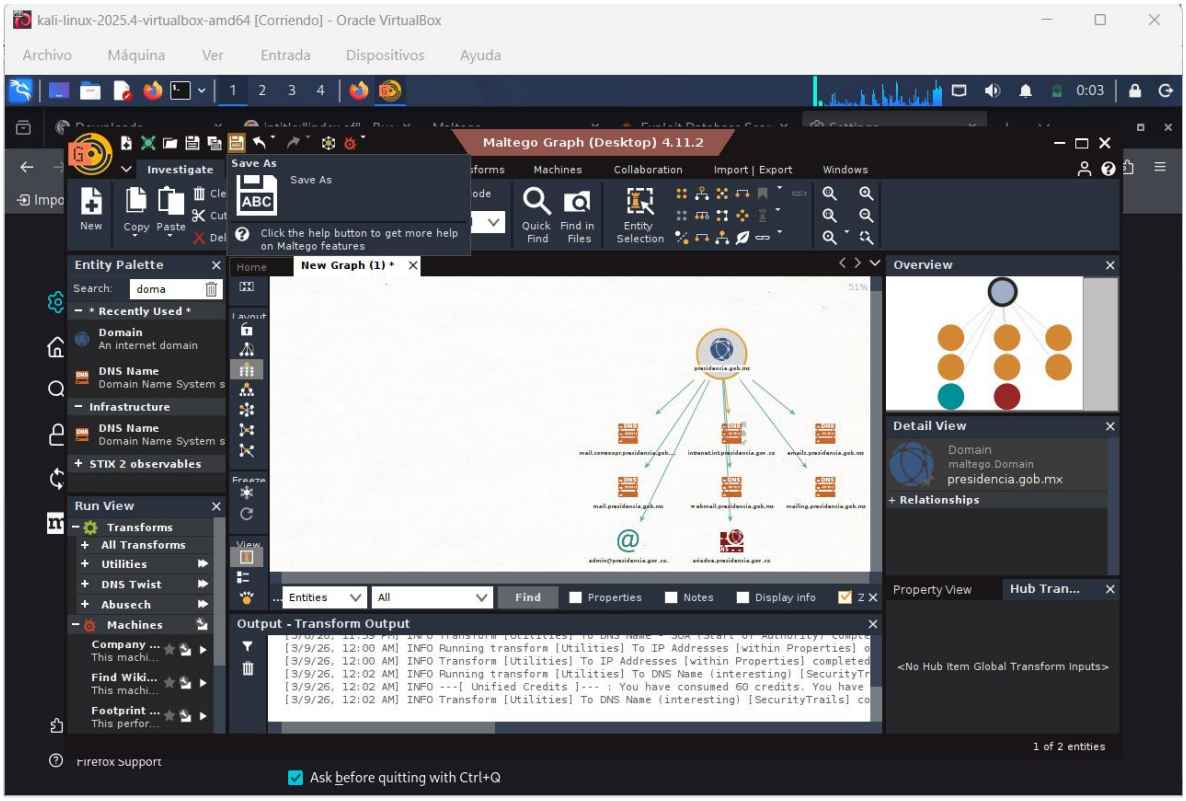
El dominio example.com es utilizado para prácticas y documentación.



Paso 3. Ejecutar transformaciones

Las transformaciones permiten descubrir relaciones entre entidades.

Domain → DNS

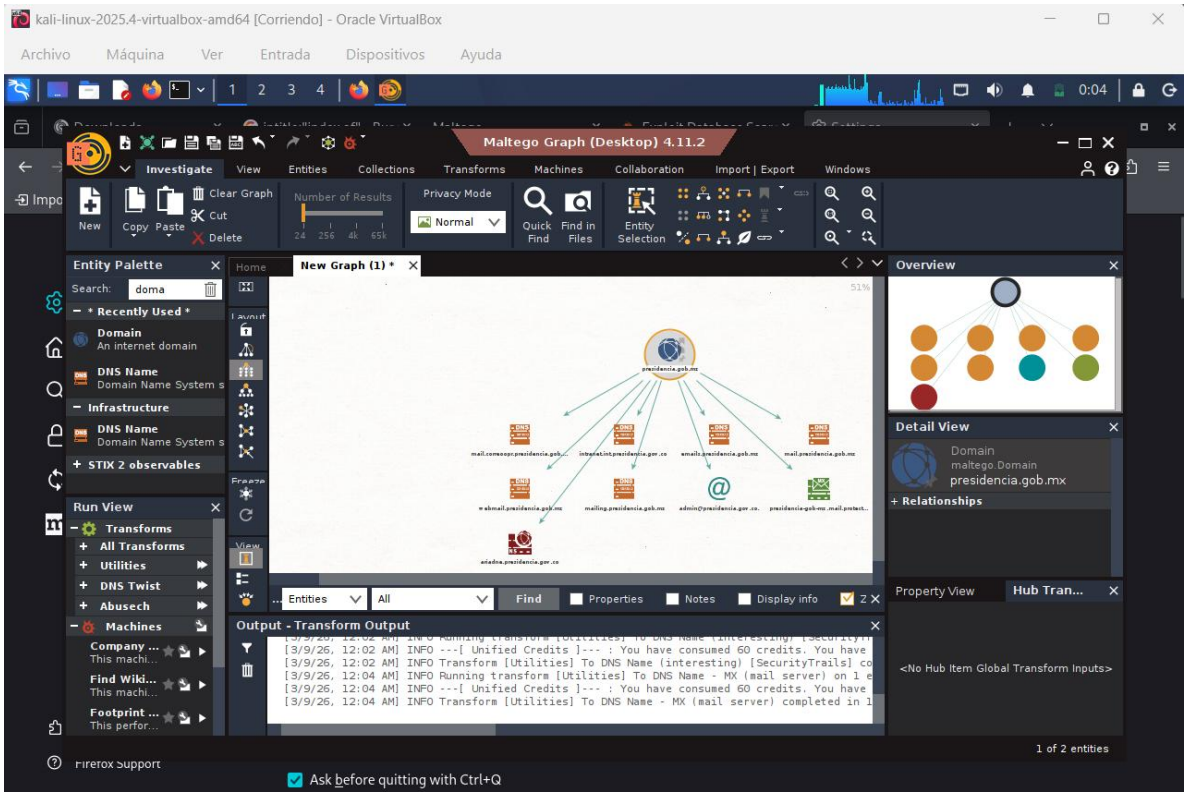


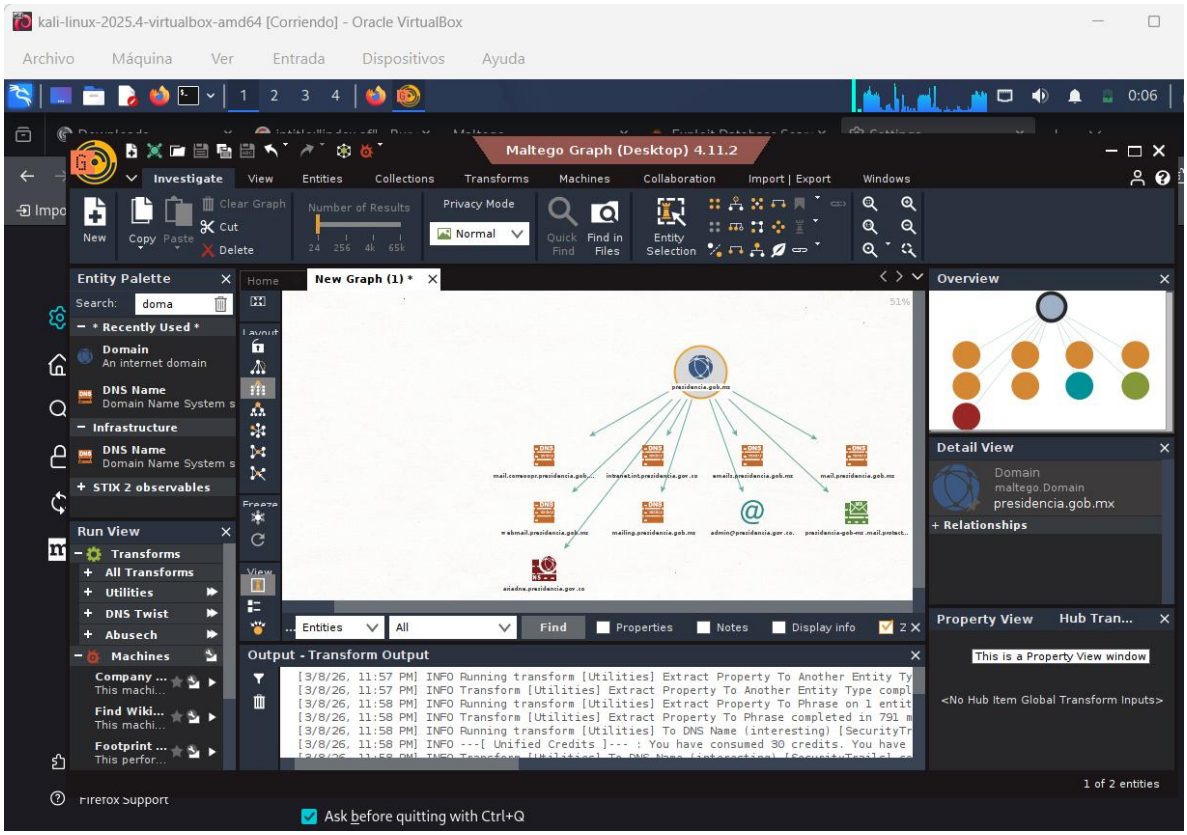
1. **Clic derecho sobre el dominio.**

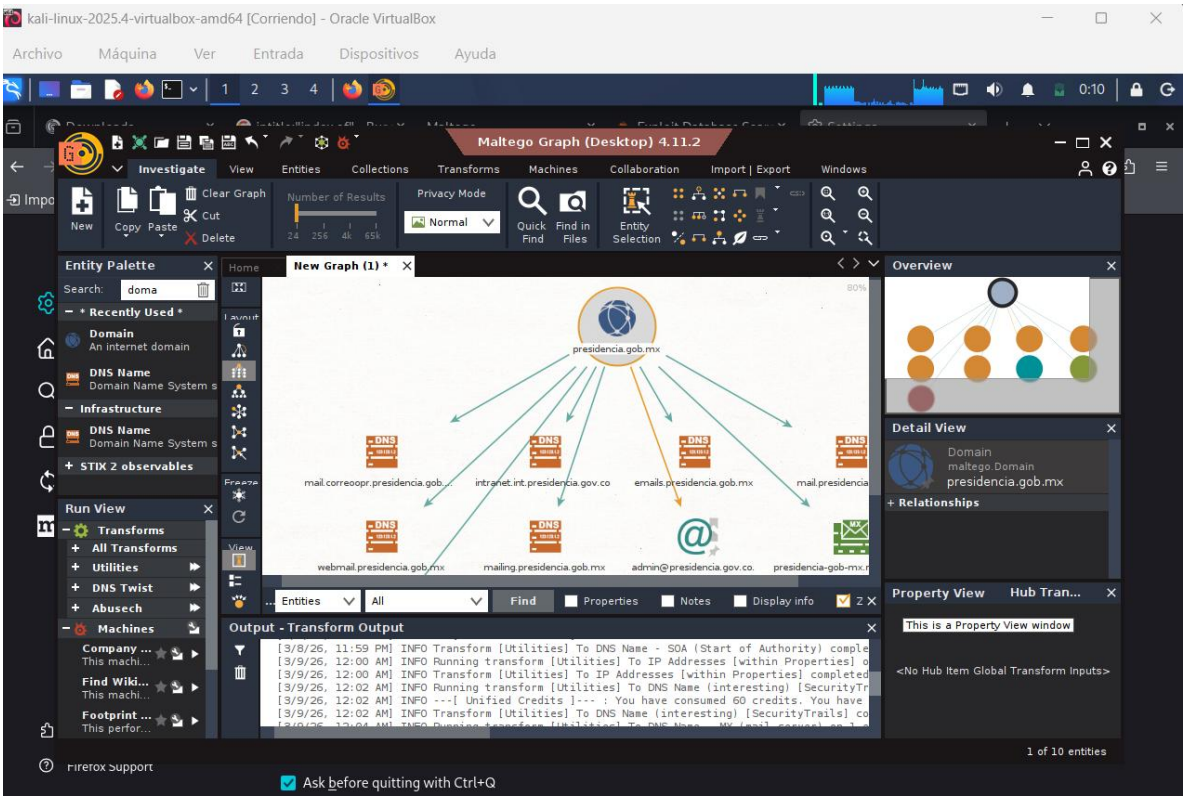
2. **Seleccionar:**

Run Transform → DNS from Domain

Esto buscará registros DNS como:



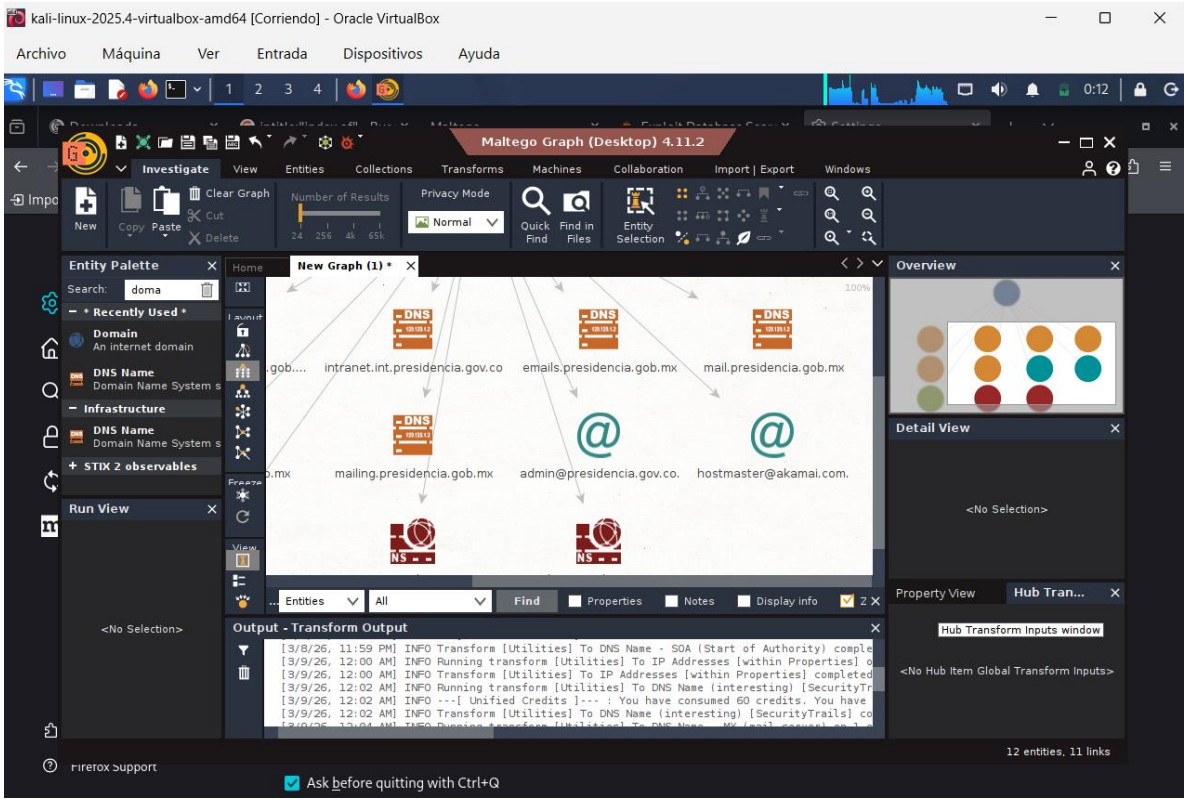




Qué muestra:

Cómo el dominio se conecta con su infraestructura DNS.

DNS → IP



Esto mostrará la dirección IP del servidor.

Ejemplo:

93.184.216.34

IP → Location

1. **Clic derecho sobre la dirección IP.**
2. **Ejecutar:**

IP → Location

Esto identifica:

- **País**
- **Ciudad**
- **Ubicación aproximada del servidor**

Resultado esperado

El grafo debe mostrar algo similar a:

Domain
DNS Record
IP Address
Location

Esto permite visualizar cómo un dominio está conectado con servidores y ubicación geográfica.